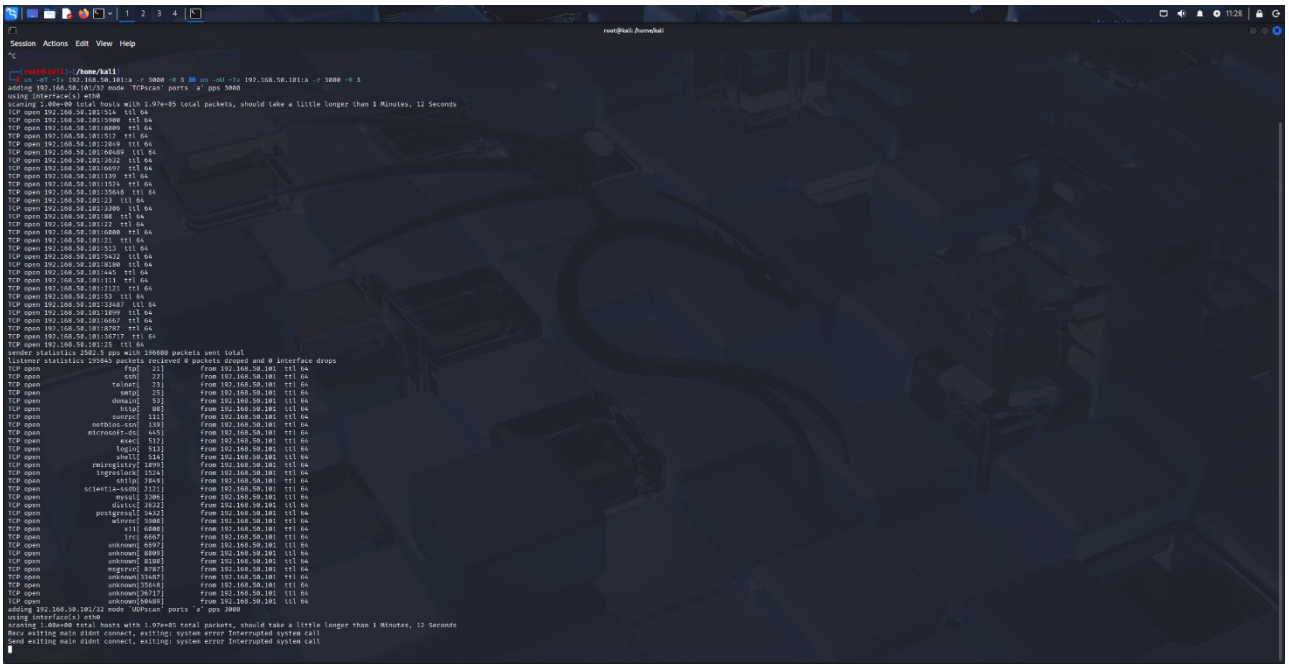


REPORT W10D4

Il report di oggi si basa sull'approfondimento dei seguenti comandi eseguiti su kali linux:

1. nmap -sn -PE ip target
2. netdiscover -r ip target
3. crackmapexec ip target
4. nmap ip target --top-ports 10 –open
5. nmap ip target -p- -sV –reason –dns-server ns
6. us -mT -Lv ip target:a -r 3000 -R 3 && us -mU -Lv ip target:a -r 3000 -R 3
7. nmap -sS -sV -T4 ip target
8. hping3 –scan known ip target
9. nc -nvz ip target 1-1024
10. nc -nv ip target 22
11. nmap -sV iptarget
12. db_import <file.xml>
13. nmap -f -mtu=512 ip target
14. masscan network -p80 –banners –source-ip ip target

Ho creato un ambiente di lavoro in virtual box mettendo una kali(192.168.50.100) e una metasploitable(192.168.50.101) sulla stessa rete. Ed ho eseguito ogni comando cercando di capire cosa facesse. Poi ho approfondito su internet.

Partiamo dal primo comando.

```
Try: sudo apt install <deb name>

┌──(kali㉿kali)-[~]
└─$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.50.100  netmask 255.255.255.0  broadcast 192.168.50.255
        ether 08:00:27:63:b0:05  txqueuelen 1000  (Ethernet)
        RX packets 61  bytes 4886 (4.7 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 18  bytes 4320 (4.2 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 8  bytes 480 (480.0 B)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 8  bytes 480 (480.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

┌──(kali㉿kali)-[~]
└─$ nmap -sn -PE 192.168.50.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-15 16:16 -0400
Nmap scan report for 192.168.50.101
Host is up (0.00073s latency).
MAC Address: 08:00:27:0D:F9:7D (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 4.57 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -sn -PE 192.168.50.1/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-15 16:16 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0061s latency).
MAC Address: 08:00:27:0D:F9:7D (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.50.100
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 17.70 seconds

┌──(kali㉿kali)-[~]
└─$
```

Significato delle opzioni

- **-sn** → *Ping Scan*

  Nmap controlla **solo quali host sono attivi**

  non scansiona le porte

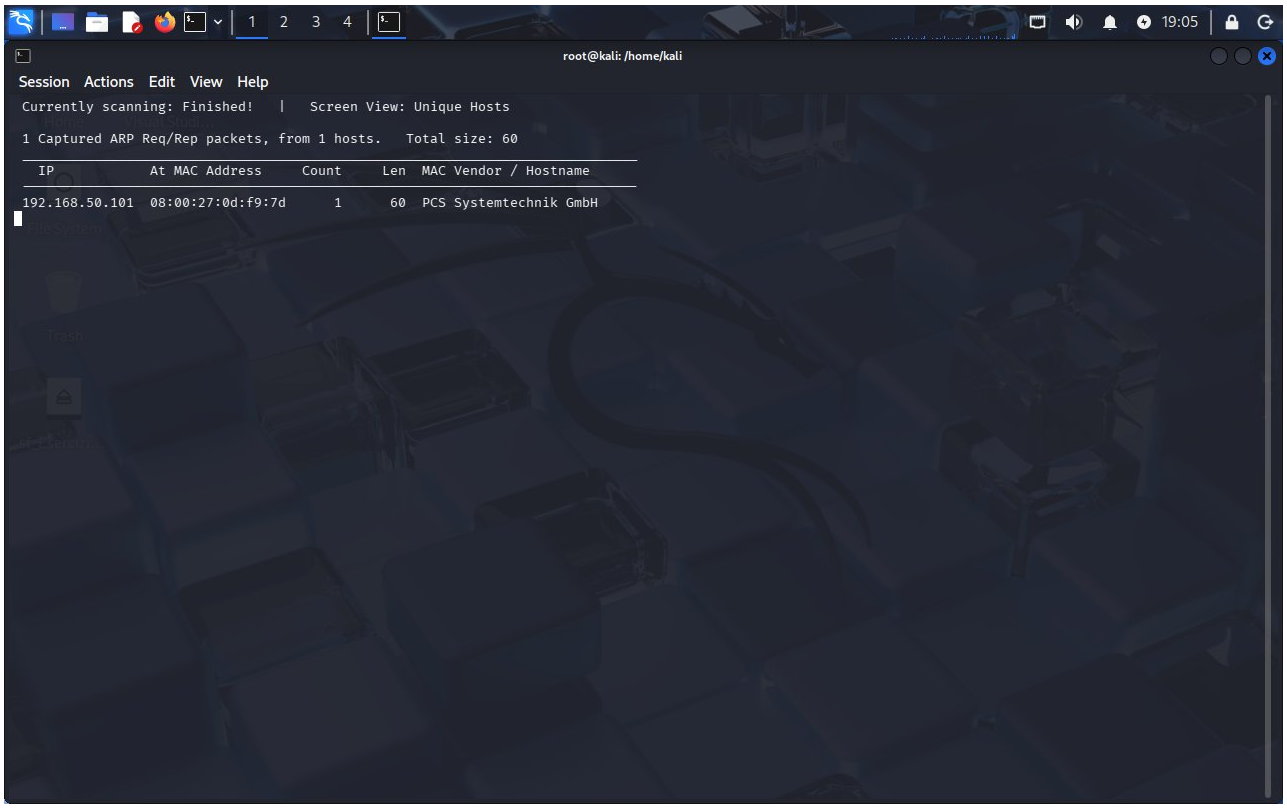
- **-PE** → *ICMP Echo Ping*

  manda un **ping ICMP Echo Request** (lo stesso tipo di ping del comando ping)

Cosa succede

1. Nmap manda un **ping ICMP** agli IP del target
2. Gli host che **rispondono** vengono segnalati come **Host is up**

In sintesi trova gli host attivi su quella rete senza però scansionarne le porte.



Netdiscover -r rete target.

Sono due comandi simili, a differenza di nmap netdiscover richiede i permessi di root.

Non invia richieste tramite ICMP (ping) ma richieste ARP

Netdiscover funziona meglio in LAN e restituisce anche gli indirizzi MAC

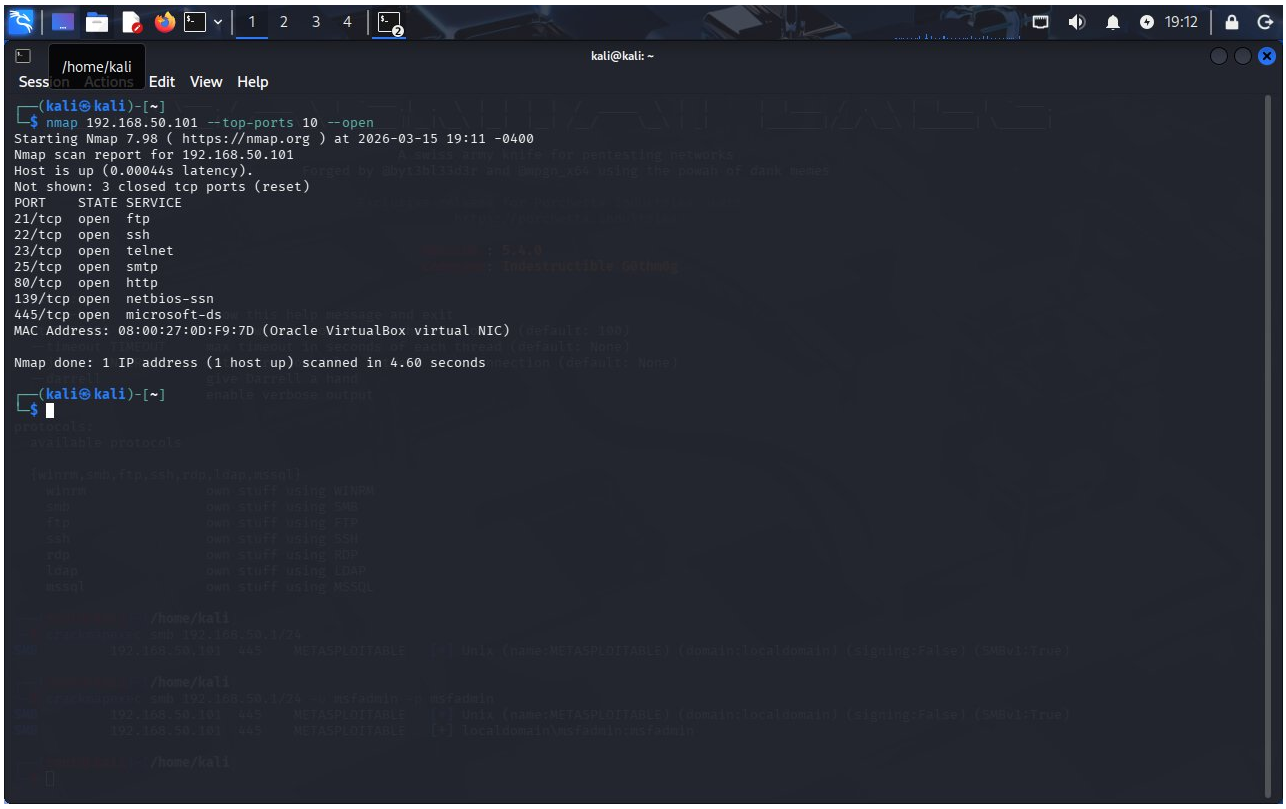
Nmap funziona meglio in rete.

```
root@kali: /home/kali
Session  Actions  Edit  View  Help

                                    A swiss army knife for pentesting networks
                              Forged by @byt3bl33d3r and @mpgn_x64 using the powah of dank memes

                                   Exclusive release for Porchetta Industries users
                                              https://porchetta.industries/

                                        Version : 5.4.0
                                        Codename: Indestructible G0thm0g

options:
  -h, --help            show this help message and exit
  -t THREADS            set how many concurrent threads to use (default: 100)
  --timeout TIMEOUT     max timeout in seconds of each thread (default: None)
  --jitter INTERVAL     sets a random delay between each connection (default: None)
  --darrell             give Darrell a hand
  --verbose             enable verbose output

protocols:
  available protocols

  {winrm,smb,ftp,ssh,rdp,ldap,mssql}
    winrm               own stuff using WINRM
    smb                 own stuff using SMB
    ftp                 own stuff using FTP
    ssh                 own stuff using SSH
    rdp                 own stuff using RDP
    ldap                own stuff using LDAP
    mssql               own stuff using MSSQL

┌──(root㉿kali)-[/home/kali]
└─# crackmapexec smb 192.168.50.1/24
SMB         192.168.50.101  445    METASPLOITABLE   [*] Unix (name:METASPLOITABLE) (domain:localdomain) (signing:False) (SMBv1:True)

┌──(root㉿kali)-[/home/kali]
└─# crackmapexec smb 192.168.50.1/24 -u msfadmin -p msfadmin
SMB         192.168.50.101  445    METASPLOITABLE   [*] Unix (name:METASPLOITABLE) (domain:localdomain) (signing:False) (SMBv1:True)
SMB         192.168.50.101  445    METASPLOITABLE   [+] localdomain\msfadmin:msfadmin

┌──(root㉿kali)-[/home/kali]
└─#
```

CrackMapExec è usato per:

- **enumerare macchine Windows**
- **testare credenziali**
- **muoversi lateralmente nella rete**

ad esempio qui l’ho usato per vedere quante macchine hanno il protocollo smb e per provare se le credenziali msfadmin utente e msfadmin password funzionavano.



Nmap target –top-ports 10 –open

scansiona solo le 10 porte più comuni

mostra solo quelle aperte

è utile per una scansione veloce iniziale nel penetration testing.

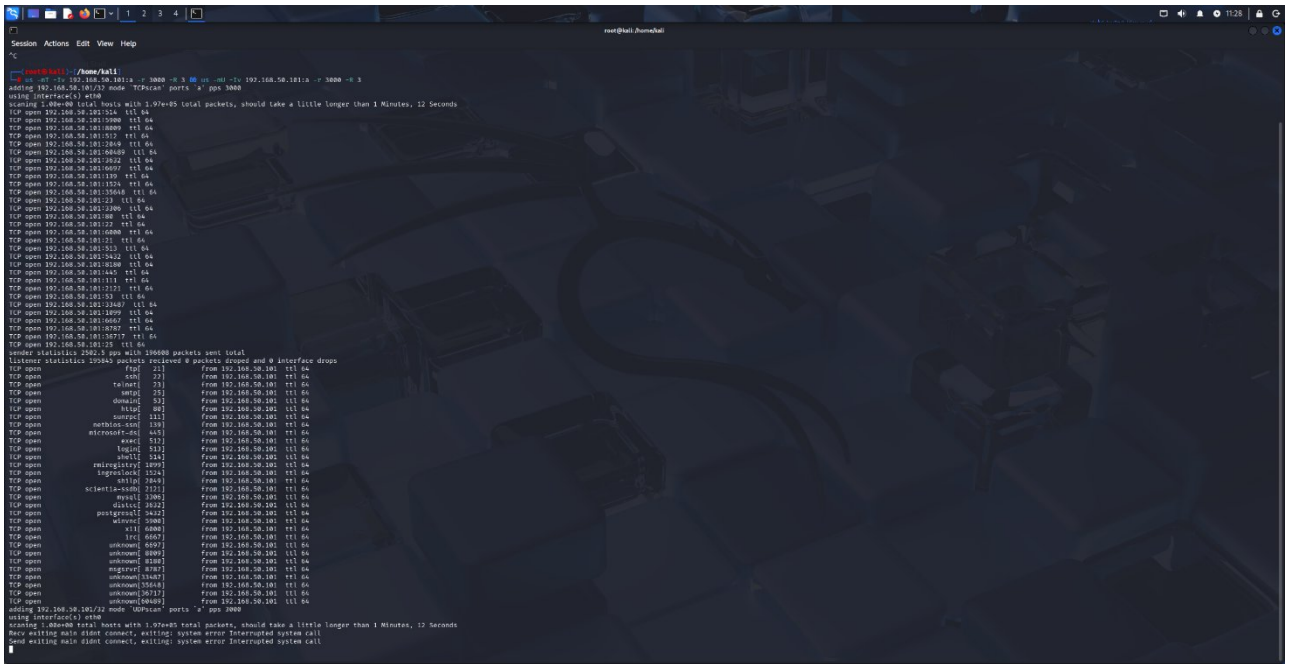
nmap <target> -p- -sV –reason –dns-server

scansione di tutte le porte

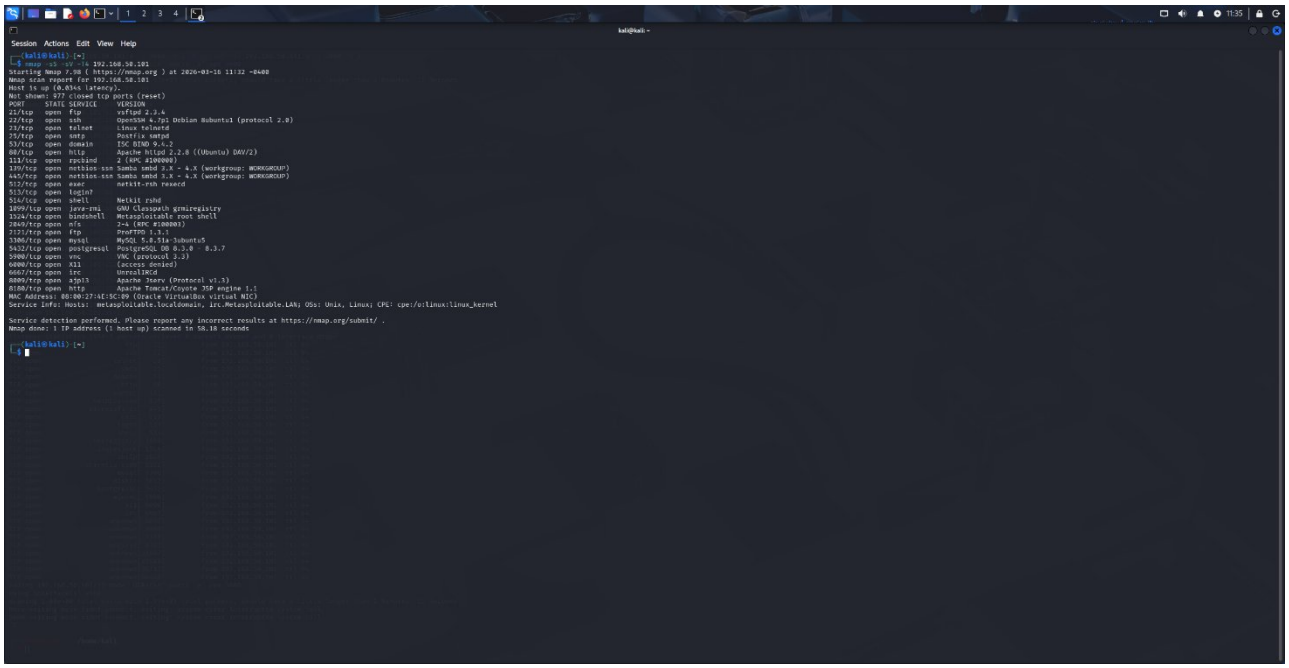
identificazione dei servizi e versioni

mostra perché una porta è considerata aperta/chiusa

usa un DNS specifico per risolvere i nomi.

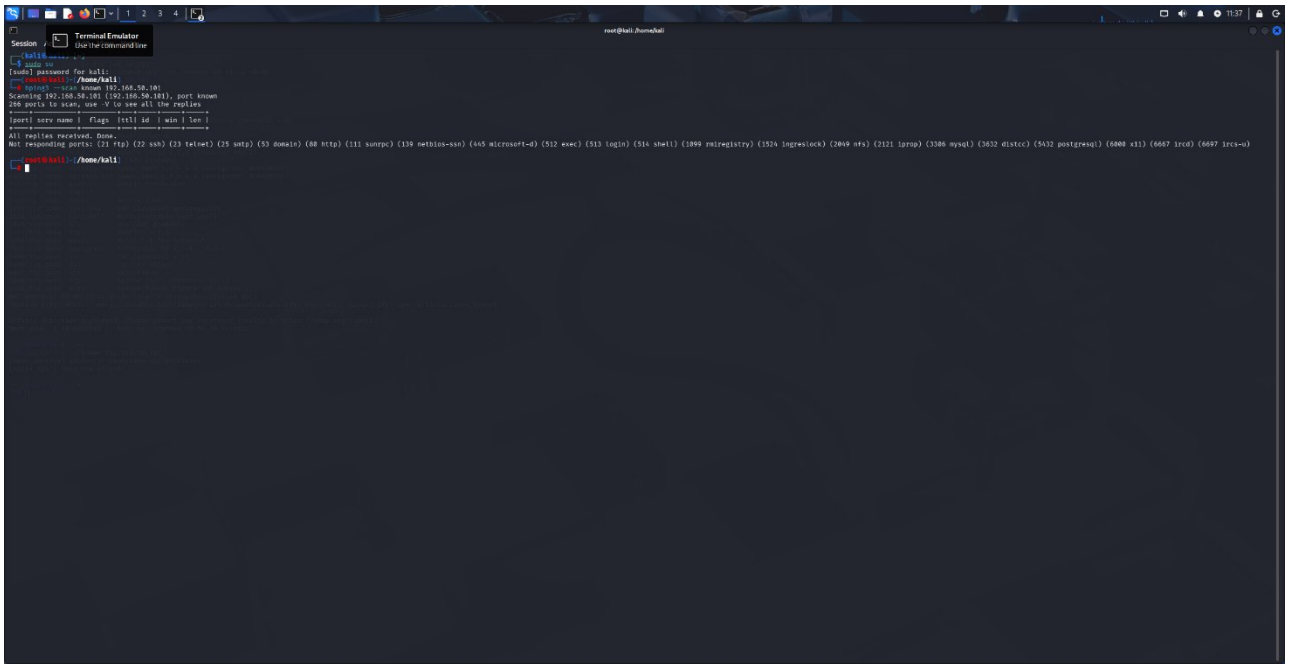


Unicorn scan serve per eseguire scansioni UDP e TCP di tutte le porte inviando 3000 pacchetti al secondo e ritentando 3 volte. E’ piu veloce di nmap. Anche se non idenfica i servizi. Infatti di solito dopo unicorn scan si usa proprio nmap per andare a identificare i servizi aperti sulle porte interessate.



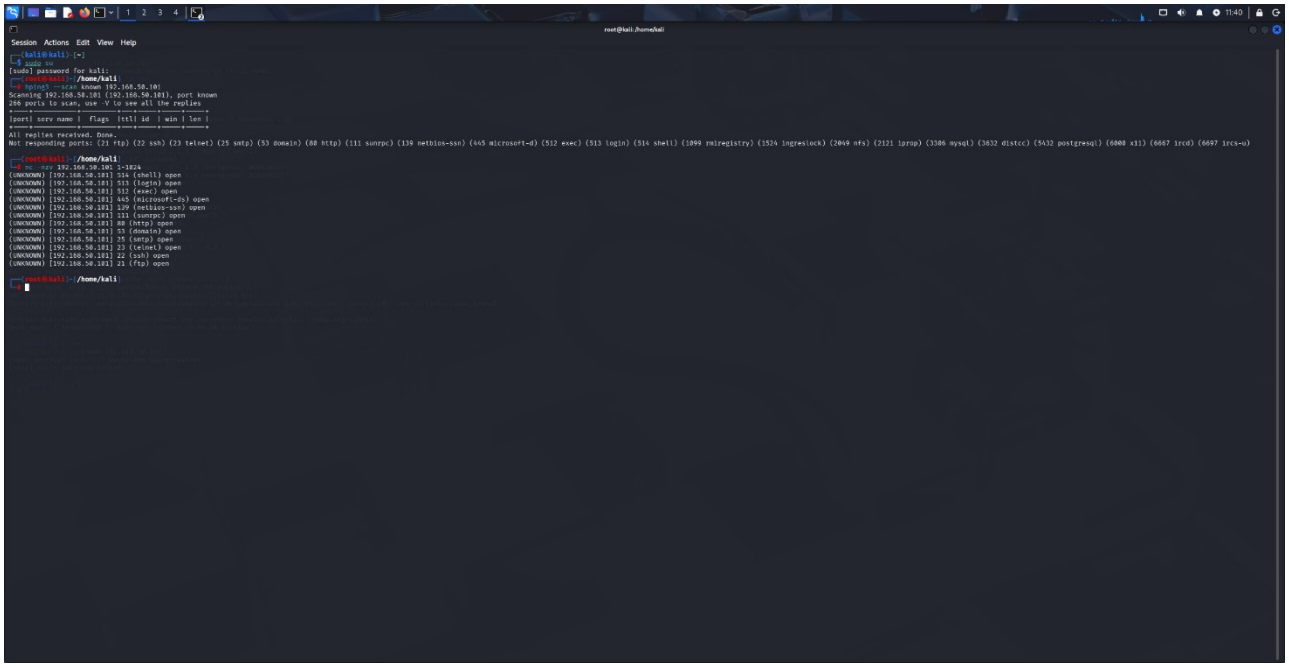
nmap -sS -sV -T4 <target>

E’ una scansione veloce(il comando T4 serve proprio per determinare la velocità della scansione) che identifica le porte aperte e i vari servizi attivi su tali porte. Inoltre abbinato a -sV per ogni servizio ne identifichiamo la versione.



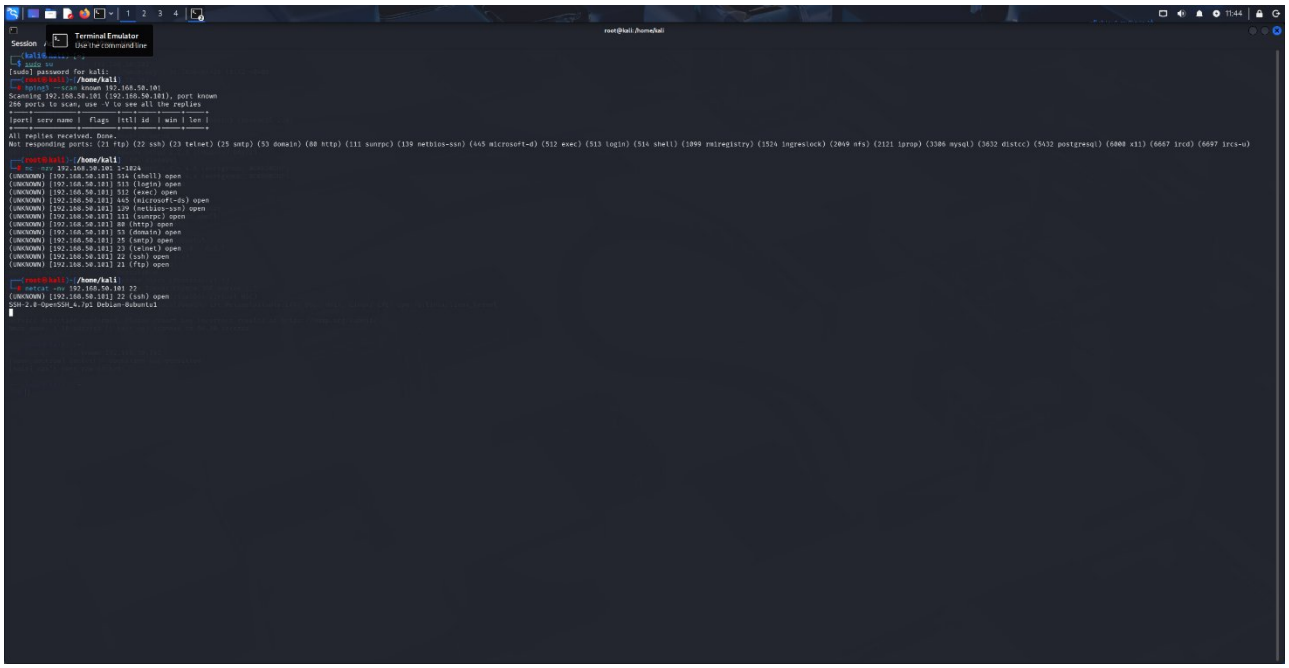
Hping3 –scan known target

Il comando serve a contattare le porte comuni per vedere quali sono aperte e quali sono chiuse in base alle porte che rispondono. Solitamente hping è utilizzato per inviare pacchetti personalizzati e per testare la rete e il firewall.



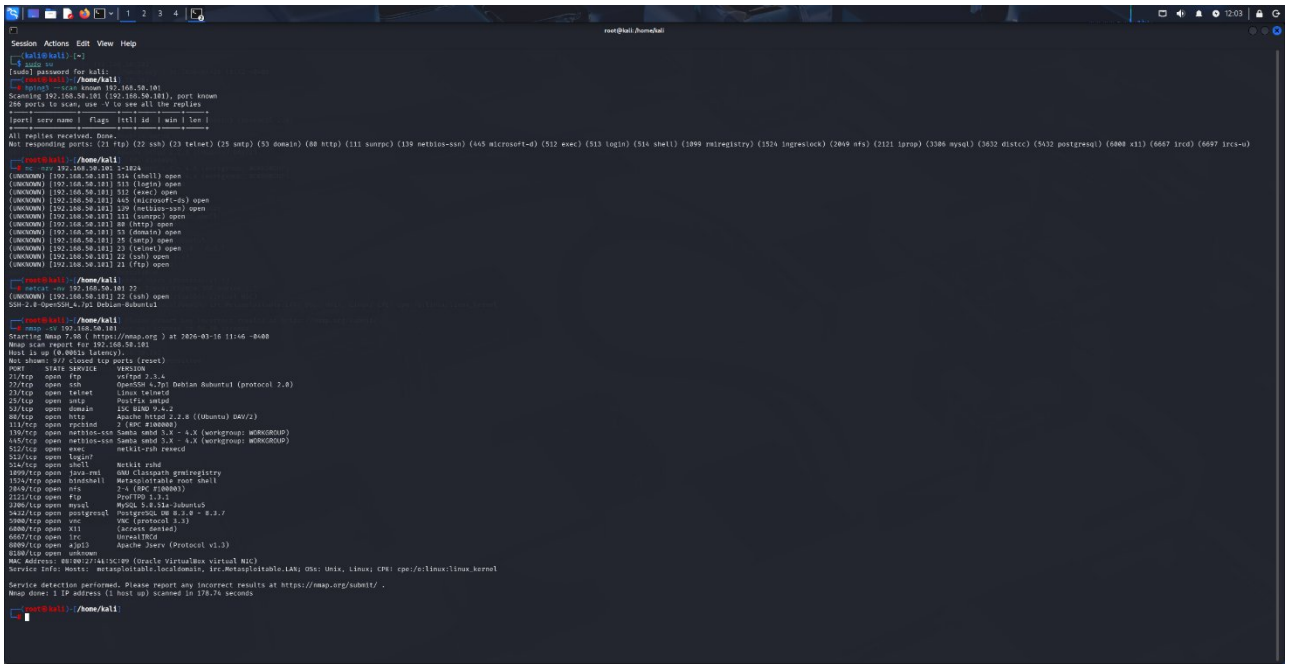
Nc -nzv target 1-1024

La funzionalità è simile a quella del comando hping 3 con la differenza che invece di generare e inviare pacchetti per analizzare la risposta tenta soltanto la connessione alle varie porte. Soltanto per vedere quali sono aperte e quali sono chiuse. Diciamo che a differenza di hping è di livello meno avanzato poiché non stabilisce una vera connessione.



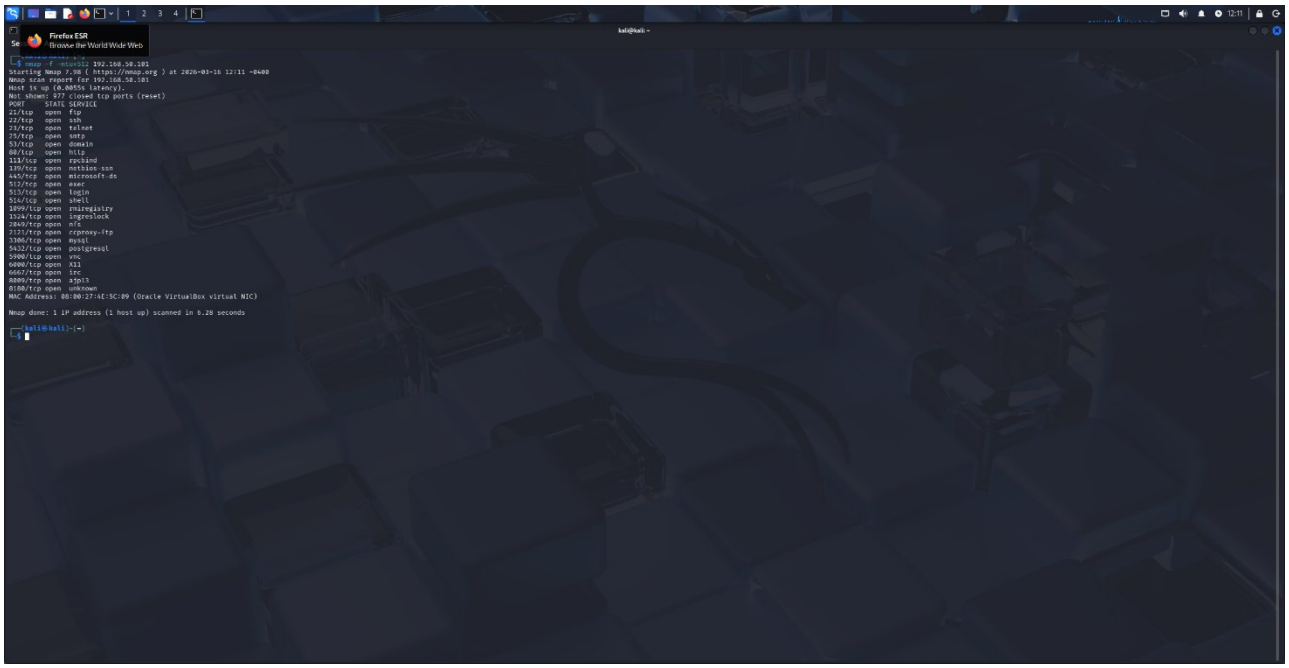
Nc -nv target numero porta

Il comando serve (Quando la porta è aperta) per stabilire una connessione con la porta da noi specificata e interagire con il servizio aperto su quella porta.



Nmap -sV target

Il comando serve semplicemente per identificare le porte aperte sull’host scansionato e trovare il servizio attivo e la sua versione



Nmap -f -mtu=512 target

Serve per fare scansione frammentando i pacchetti in modo tale che il firewall non riesca a rilevare attività sospetta e non comprometta la scansione del dispositivo.

Il comando masscan target -p80 –banners –source-ip ip

Serve per trovare all’interno della rete tutti gli host con la porta 80 attiva e mostrare i banner che mostrano i servizi attivi e la loro versione. Con l’ultimo comando specifichiamo da quale macchina all’interno della rete deve inviare i pacchetti.

Vulnerabilità trovate:

vsftpd 2.3.4 Backdoor

Porta:

21

Servizio:

vsftpd 2.3.4

Vulnerabilità nota:

- backdoor remota
- permette accesso shell non autorizzato

Telnet attivo

Porta:

23

Problema:

- protocollo non cifrato
- credenziali trasmesse in chiaro.

Samba vulnerabile

Porte:

139
445

Possibili vulnerabilità:

- accesso a condivisioni
- exploit Samba.

Apache HTTP vulnerabile

Porta:

80

Possibili problemi:

- configurazioni deboli
- versioni obsolete.

Servizi di rete eccessivi

La macchina espone molti servizi:

- FTP
- SSH
- Telnet
- SMTP
- HTTP
- SMB

Questo aumenta la superficie di attacco.

Raccomandazioni

Per migliorare la sicurezza:

1. aggiornare i software vulnerabili
2. disabilitare servizi inutili
3. usare protocolli sicuri (SSH invece di Telnet)
4. limitare accesso tramite firewall

5. applicare patch di sicurezza.

Conclusione

L'analisi dimostra che la macchina Metasploitable contiene numerose vulnerabilità critiche che permettono:

- accesso remoto
- compromissione del sistema
- escalation di privilegi.

Questo la rende ideale per esercitazioni di penetration testing.

Facoltativo

Un firewall analizza il traffico di rete e decide se bloccarlo o permetterlo.
Le tecniche di evasione cercano di mascherare o modificare il traffico in modo che il firewall non riconosca una scansione o un attacco.

Tecniche principali di evasione

Frammentazione dei pacchetti

Questa tecnica divide i pacchetti in frammenti più piccoli.

Idea:

- il firewall potrebbe analizzare solo il primo frammento
- i frammenti successivi contengono dati che sfuggono al controllo.

Esempio con Nmap:

```
nmap -f <target>
```

oppure

```
nmap -f --mtu 512 <target>
```

Effetto:

- i pacchetti TCP vengono spezzati
- alcuni IDS/Firewall non riescono a ricostruirli correttamente.

Manipolazione dei pacchetti TCP

Strumenti come hping3 permettono di creare pacchetti TCP personalizzati.

Si possono modificare:

- flag TCP
- dimensioni
- sequenze.

Esempio:

hping3 -S -p 80 <target>

Questo invia pacchetti SYN manualmente.

Scopo:

- testare il comportamento del firewall
- individuare porte filtrate.

Modifica della velocità della scansione

Alcuni firewall rilevano molte connessioni in poco tempo.

Soluzione:
ridurre la velocità della scansione.

Esempio con Nmap:

nmap -T1 <target>

Oppure scansioni molto lente.

Effetto:

- il firewall potrebbe non riconoscere il pattern di scanning.

Uso di porte sorgente specifiche

Alcuni firewall permettono traffico proveniente da porte considerate sicure.

Esempio:

nmap --source-port 53 <target>

Qui il traffico sembra provenire dalla porta DNS.

Decoy Scan (indirizzi IP falsi)

Una scansione può essere nascosta tra altri indirizzi IP.

Esempio:

nmap -D RND:10 <target>

Effetto:

- il firewall vede molti IP
- è difficile identificare quello reale.

Idle Scan

Tecnica avanzata di scansione indiretta.

Il target vede traffico provenire da un altro host (zombie).

Esempio:

nmap -sI zombie_IP <target>

Vantaggi:

- anonimato
- difficile tracciabilità.

Scansione con pacchetti incompleti

Alcune scansioni non completano la connessione TCP.

Esempio:

nmap -sS <target>

Detta SYN scan.

Effetto:

- più difficile da registrare nei log.

Uso di scanner ad alta velocità

Strumenti come Masscan inviano milioni di pacchetti.

Questo può:

- sovraccaricare sistemi di rilevamento
- individuare rapidamente porte aperte.

Limiti delle tecniche di evasione

I firewall moderni includono:

- IDS (Intrusion Detection System)
- IPS (Intrusion Prevention System)
- Deep Packet Inspection

Questi sistemi possono:

- ricostruire frammenti
- analizzare pattern di scansione
- bloccare traffico sospetto.

Contromisure di sicurezza

Per difendersi da queste tecniche si utilizzano:

1. stateful firewall
2. intrusion detection systems
3. rate limiting
4. analisi dei pacchetti frammentati
5. monitoraggio del traffico anomalo.